

UNIDAD DE TRABAJO 1. Prevención de ataques de ciberseguridad.

Principios de la ciberseguridad, conceptos, normas, vectores de ataque, medidas de prevención, normativa de protección del puesto de trabajo, plan de formación y concienciación en materia de ciberseguridad.

OBJETIVO: En esta unidad el alumnado conocerá los principales conceptos de ciberseguridad, sus categorías, clasificación, impacto y dimensión dentro del área empresarial. Conocerá e identificará el marco normativo a utilizar durante el presente módulo para lograr la implantación de los controles, políticas y procedimientos respetando y cumpliendo con los principales puntos del esquema nacional de ciberseguridad. Conocerá los principales puntos de la seguridad física y lógica donde deberán aplicarse políticas y procedimientos de prevención. Conocerá los principales riesgos y vectores de ataque realizados por los diferentes actores de la industria del cibercrimen, así mismo será capaz de conocer y aplicar la normativa de protección del puesto de trabajo y diseñar un plan de formación y concienciación dentro de una organización.

Contenido del documento.

[Completar con lectura Glosario términos de Ciberseguridad](#)

Introducción a la Ciberseguridad	2
Categorías de protección	4
Categorías de amenazas según el actor y CaaS	5
Datos sobre seguridad de la información y ciberseguridad.	11
El impacto de la ciberseguridad	11
Ejemplos de casos reales	11
Dimensiones, áreas y ubicación de la ciberseguridad.	15
Las dimensiones de la seguridad	15
Otros conceptos de seguridad	15
Áreas de actuación de la Ciberseguridad	16
Ubicación de la Ciberseguridad	16

Introducción a la Ciberseguridad

Durante la presente trayectoria formativa obtendremos los conocimientos adecuados para identificar los elementos dentro una infraestructura computacional susceptibles de ser atacados, los diferentes tipos de ataque que pueden sufrir, como la omnipresencia de la tecnología en nuestro entorno afecta a nuestra privacidad o que herramientas disponemos para minimizar el riesgo.

Antes de comenzar el presente curso es adecuado tener clara la siguiente premisa: conseguir el 0% de riesgo es inviable económicamente. Salvo que el sistema informático sea realmente simple o esté totalmente aislado, protegerlo completamente implicaría una inversión en infraestructura, en capital económico y humano en la mayoría de las ocasiones superior al software, hardware o redes de computadoras que se pretende proteger. Por lo tanto, hay que procurar una inversión de tiempo y económica adecuada, regulada y actualizada para que la protección del sistema implique un mayor coste para el agente atacante que los beneficios que le pudieran reportar.

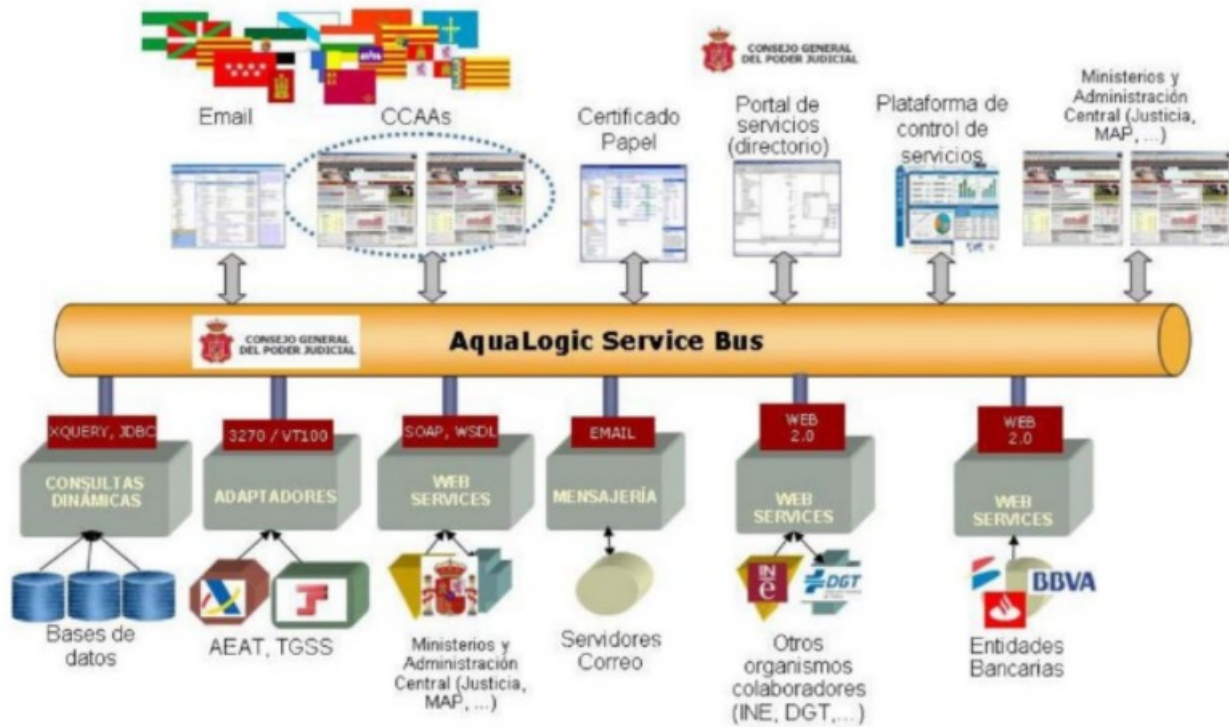
Otro punto a destacar es que el riesgo anterior se acentúa en el caso que el factor humano interactúe con el sistema. Es interesante saber que los mecanismos a pruebas errores, como el sistema Poka-Yoke de Toyota, normalmente se centran en imposibilitar los errores humanos o resaltan, de manera visual o sonora, dichos errores en tiempo real para su fácil revisión y corrección.

Desde 1969, la creación de la red Arpanet supuso el origen de los múltiples protocolos de interconexión entre ordenadores que establecieron las primeras bases de lo que hoy conocemos como Internet.

La descentralización de los sistemas informáticos realizada desde mediados de los 90, la democratización de la difusión de contenidos y la guerra de los navegadores que han llegado a facilitar la utilización de Internet sin tener conocimientos informáticos ha supuesto una de las mayores revoluciones sociales, culturales, económicas... de nuestra historia reciente.

El grado de avance actual de la tecnología ha permitido disponer, en tiempo real, de casi todo el conocimiento humano acumulado en la Red desde múltiples dispositivos como ordenadores, tablets, teléfonos móviles, smartwatches, televisiones, electrodomésticos, coches, drones, lámparas, interruptores.

Actualmente, cualquier entidad u organización, pública o privada, para obtener una mejora productiva significativa, ha tenido que invertir en una digitalización de su modelo productivo o funcional. Como ejemplo, instituciones educativas, sanitarias, fiscales, financieras o juzgados hacen uso de las posibilidades de la Red para agilizar tareas administrativas, comunicación de laudos y, en resumen, para funcionar con una mayor eficiencia y eficacia en el momento de almacenar, gestionar y compartir información, independientemente de su volumen.



Punto Neutro Judicial. Red de servicios informáticos al servicio de los órganos judiciales españoles.

Es decir, el mundo digital atesora cada vez más y más información, y permite su gestión de manera deslocalizada e inmediata, lo cual, supone indiscutibles ventajas, pero también una gran amenaza: que dicha información sea accedida por agentes externos no autorizados o incluso malintencionados. El problema se agrava cuando la información sustraída o modificada es información sensible o confidencial, que abarca a aquella información de naturaleza privada y personal, entre la que se incluyen datos personales, bancarios, sanitarios, contraseñas, domicilio o cualquier otra cuya modificación, destrucción o revelación podría producir daños graves al propietario.

La ciberdelincuencia, entendida como cualquier actividad ilegal llevada a cabo mediante el uso de medios informáticos y normalmente ejecutada a través del uso de Internet. Los ciberdelincuentes pueden ser personas aisladas, grupos organizados o incluso facciones con apoyo y financiación estatal.

Para entender la ciberseguridad, es necesario manejar varios conceptos:

- Seguridad: Ausencia de peligro o riesgo // Sensación de total confianza que se tiene en algo o alguien.
- Seguridad de la información: La seguridad de la información abarca las medidas y actividades que intentan proteger los activos de información, es decir, la protección de la información o datos que tienen valor para una organización, a través de la reducción de riesgos y mitigando las posibles amenazas. Estos activos se pueden encontrar en diferentes formatos, por ejemplo en formato digital, de forma física o en forma de ideas o conocimientos de personas que pertenecen a la organización.

La ciberseguridad es el área de las tecnologías de la información y la comunicación (TIC) centrada en la constante práctica y esfuerzo por proteger toda información, software e infraestructura computacional, haciendo énfasis en la defensa de aquellos sistemas o elementos conectados a Internet, contra todo ciberataque.

La ciberseguridad, a nivel profesional, está ejercida por expertos en el área de la seguridad informática atendiendo a unos principios éticos y laborales que aseguran la utilización de su experiencia y conocimientos para proteger y no para perjudicar a los sistemas objetivo por sus actividades.

Igualmente, cualquier individuo con conocimientos sobre ciberseguridad puede beneficiarse de un bagaje de conocimientos y buenas prácticas que le ayudarán a proteger sus datos personales y aquella información de la que es responsable en su entorno laboral.

Un pronóstico plausible, en un futuro cercano, es que el uso de Internet se extienda a prácticamente toda la población existente y por varios dispositivos de manera concurrente (Teléfonos móviles, ordenadores, coches, electrodomésticos...).

Es decir, se presenta un caldo de cultivo perfecto para aquellos individuos, entidades o gobiernos que quieran utilizar Internet en su propio beneficio, pero de manera malintencionada.

Es difícil realizar una estimación exacta del número y grado de ataques que se realizan a través de Internet pero, por ejemplo, se puede realizar una estimación atendiendo a los datos ofrecidos de iniciativas como ["Cybermap"](https://cybermap.kaspersky.com/es) de la compañía internacional dedicada a la seguridad informática Kaspersky.

"Cybermap" (<https://cybermap.kaspersky.com/es>) es un mapa dinámico que se actualiza en tiempo real en relación a las principales amenazas y ataques cibernéticos identificados gracias a las fuentes de datos que se corresponden a los distintos servicios de Kaspersky.

Categorías de protección

Dentro de la ciberseguridad existen diferentes categorías de acuerdo a su objetivo de protección:

- Seguridad de red: Se trata de la práctica de proteger las redes informáticas contra los intrusos, ya sean ataques dirigidos o ataques oportunistas (como la infección por un malware que se propaga de forma indiscriminada).
- Seguridad de aplicaciones: Se focaliza en mantener el software y los dispositivos (tanto los servidores como los de punto final como portátiles o móviles). Una aplicación comprometida podrían dar acceso a la información que está gestionando, así como un virus en un portátil.
- Seguridad de los datos: Se centra en asegurar la integridad y privacidad de la información, tanto en tránsito como almacenada.
- Seguridad operacional: Incluye los procesos y decisiones para el manejo y protección de los activos de datos, como la realización y aseguramiento de copias de seguridad, la gestión de vulnerabilidades, la gestión del cambio y de la capacidad, la monitorización de eventos de seguridad, etc.
- Recuperación ante desastres y continuidad de negocio: Define como una organización responde a un incidente de seguridad o cualquier otro evento que cause una pérdida de datos o de las operaciones. Las políticas de recuperación ante desastres dictan cómo la

organización restaura las operaciones e información a la misma capacidad operativa antes del evento. La continuidad de negocio se centra en definir y aplicar un plan que permita a la organización operar en medio del desastre con recursos limitados.

- Concienciación de usuarios finales: Se centra en el factor menos predecible de todos, las personas. Asegurar que los usuarios siguen unas pautas de trabajo seguras, así como que son capaces de poder detectar y/o notificar un posible ataque (como un correo fraudulento) es crítico para proteger a la organización.

Categorías de amenazas según el actor y CaaS

Las siguientes tipologías de actores son una amenaza para la ciberseguridad:

- Ciberactivistas: Motivados políticamente buscan dar a conocer una causa o bien castigar a una organización o gobierno que consideran está actuando de forma poco ética, ya sea por temas ecológicos, trato a los empleados, libertad, etc. Sus actividades van desde el desfiguramiento de páginas web a la recopilación de información confidencial.
- Criminales: Desde el espionaje corporativo al cobro de rescates por ransomware, existe una amplia gama de crímenes que se pueden cometer de manera remota y bastante anónima. Así mismo ha surgido una industria de intermediarios que ofrecen desde listas de correos para enviar spam o la infraestructura necesaria para dichos envíos masivos hasta malware para su uso en terceros.
- Terroristas: Con el avance de las tecnologías y su progresiva asimilación en todos los ámbitos, muchos grupos terroristas se han dado cuenta de que un ataque digital podría tener consecuencias catastróficas para un país, por ejemplo atacando infraestructura crítica.
- Agentes estatales: Muchos gobiernos han creado unidades digitales en sus ejércitos para tener todo tipo de capacidades ofensivas. Desde poder cortar suministros básicos en un país hasta ejercicios de desinformación en elecciones. La línea con los terroristas no está clara a veces, como agentes de gobiernos como Corea del Norte o Irán, así como con los grupos criminales, dado que estos mismos grupos se dedican a robo de bancos, uso de ransomware, etc. en paralelo como medio de financiación para dicho país (siendo Corea del Norte el más prolífico de todos).

La ciberdelincuencia, es una realidad. Aumenta su actividad año tras año y no se limita únicamente a la piratería de películas, series, videojuegos u otro material audiovisual.

Los ciberdelitos también abarcan actividades del siguiente calibre:

- Amenazas.
- Extorsión.
- Revelación de secretos.
- Injurias y calumnias.
- Exhibicionismo.
- Robos.

- Estafas.
- Inutilización de sistemas vitales enemigos como infraestructura militar, financiera, sanitaria...

Un ataque cibernético satisfactorio puede llegar a tener una afectación de nivel global. Por ejemplo, el ataque perpetrado mediante el uso del software malicioso WannaCry, desarrollado hipotéticamente en Corea del Norte, en base a las vulnerabilidades almacenadas por la Agencia Central de Inteligencia (CIA) y robadas a la Agencia de Seguridad Nacional de Estados Unidos (NSA) logró, el 12 de mayo de 2017, un ataque masivo a 200.000 equipos informáticos en aproximadamente 150 países:



Gracias a iniciativas como Cybermap, [Netscout Cyber Threat Horizon](#) o [FireEye Cyber Threat Map](#) se puede comprobar que:

- El número de ciberataques crece de forma continuada y se cuentan por millones de incidencias anuales.
- La naturaleza de los ataques es diversa y aumenta cada día.
- Los ataques más potentes son realizados de manera planificada, remota, automática y de alcance mundial.
- Los innumerables dispositivos inteligentes, como asistentes de voz, farolas automáticas o cámaras de videovigilancia, conectados a Internet (IoT o Internet de las Cosas) ofrecen la

posibilidad de explotar nuevas vulnerabilidades en las redes existentes, por ejemplo, controlando miles de estos dispositivos para formar una botnet y desbordar un servidor objetivo mediante un ataque masivo y sincronizado.

La industria del cibercrimen o CaaS o Crime as a service han acelerado la evolución de la ciberseguridad que actualmente se ve como un valor agregado a las operaciones de la empresa. Las organizaciones del CaaS realizan actividades para enriquecerse de forma ilícita, realizando robo de datos bancarios, secuestro de información para pedir rescate, infecciones para espiar o crear una red de bots o botnet. Estos son grupo organizados con medios técnicos y humanos que ofrecen servicios delictivos a cambio de dinero, utilizan medios tecnológicos más avanzados que los destinados a prevenirlos, muchas de ellas realizan marketing y comunicación como cualquier otro negocio para difundir y publicitar sus actividades, establecen sistemas de confianza y garantía de sus productos.

Mueven al año altas cantidades de dinero, se estima sobre un 0,8% del PIB mundial, el cobro se realiza mediante cuentas falsas, intermediarios, monedas virtuales. Se aprovechan del anonimato mediante herramientas tecnológicas para esconder su identidad y las acciones para ello son la suplantación de identidad de terceros, utilizando proxys anónimos o mediante la red Tor.

El Malware como servicio (MaaS) es el diseño de software malicioso a la carta. Con los cuales se puede llegar a realizar fraudes en transacciones económicas como el pago online con tarjetas de crédito robadas o clonadas, blanqueo online de capitales mediante transferencias bancarias a cuentas abiertas con identidad falsa o utilizando muleros, tarjetas de prepago, transferencias electrónicas...

Otros de los servicios del CassS son los delitos relacionados con ingeniería social para obtener información sensible, campañas de spam, phishing... Aprovechando la buena fe de las personas. Intrusión en redes y ejecutar acciones como robo de información de empresas, extorsión, protesta o sabotaje, generalmente suelen ser encargos de la competencia, competidores, empleados descontentos...

Las empresas deben considerar la ciberseguridad como un **valor añadido**, hoy en día clientes e inversores tienen en cuenta aspectos como resiliencia y confiabilidad en el momento de contratar un servicio o dejar sus datos en manos de otra empresa, si el cliente confía en una organización, la organización no puede verse afectada por incidentes de seguridad que pongan en peligro la información propia o del cliente o un incumplimiento de las obligaciones con la Administración.

Algunos **puntos clave que constatan que la ciberseguridad es un valor en la empresa** son:

- Invertir en mejorar las capacidades de sus empleados mediante formación
- Establecer recursos tecnológicos para prevenir los efectos del cibercrimen
- Incorporar la ciberseguridad a la cultura de la organización
- Compartir las mejores prácticas sobre amenazas
- De forma interna y con otras compañías de su cadena de valor
- Establecer contramedidas para evitar ciberataques.

En algunos casos si la información de la empresa no es de utilidad el ciberdelincuente:

- Aprovecha la infraestructura TIC empresarial utilizándose como bots

- Para inundar de spam la red
- Realizar ataques contra otras compañías
- Criptoanálisis de monedas...

En cuanto a la evolución de la ciberseguridad

- En los años 70 prevalecía la protección frente a desastres naturales es decir la Seguridad física
- En la actualidad existen tecnologías y capas de protección para proteger la superficie de ataque
- Antivirus, herramientas de protección de redes...
- Protección de la información Ciberseguridad.

La situación se ha agravado desde el inicio de la pandemia mundial provocada por la enfermedad del coronavirus (COVID-19). La situación de confinamiento ha forzado a las empresas a ofrecer a sus trabajadores la continuación de sus actividades mediante teletrabajo, lo que ha provocado que:

Los equipos utilizados por los profesionales para conectarse de manera remota a la red de la empresa han supuesto una nueva vulnerabilidad explotable.

Las herramientas de Escritorio Remoto, si no se controla su actividad y canales de conexión, son una puerta de entrada rápida y directa a los sistemas e información atesorados por las compañías.

La adopción rápida y generalizada de aplicaciones de trabajo desde casa ha ejercido una presión considerable sobre la seguridad de los equipos corporativos, que deben ser protegidos sin obstaculizar o imposibilitar el trabajo de los empleados para evitar un perjuicio en la productividad.

Por mera razón de probabilidad, cuanto más grande es la empresa, y más trabajadores tenga asignados en un entorno de teletrabajo, más probabilidades tendrá de sufrir un ataque. Aun así, todas las empresas, independientemente de su tamaño, no están exentas de riesgo.

Por lo anterior, la aplicación de medidas efectivas de ciberseguridad es especialmente necesaria y desafiante hoy en día, porque incluso hay más dispositivos que personas conectados a Internet y los atacantes hacen continuas inversiones para mejorar su radio de acción y eficacia.

Además, es útil saber que actualmente existe una guerra cibernética en la que los ataques informáticos se utilizan cada vez más como un método de represalia en los conflictos donde la guerra militar convencional no es viable por razones políticas, económicas o sociales.

Por ello, en los próximos años, las naciones experimentarán un considerable aumento en los ciberataques y en su severidad, por lo que necesitan y necesitarán profesionales de la ciberseguridad para proteger a sus ciudadanos y su infraestructura. Por ejemplo, la ONU publicó, el 5 de marzo de 2019, un informe de 379 páginas en el que se corrobora que Corea del Norte dispone de una formidable división de hackers, no sólo para la realización de ataques subversivos en otras áreas del planeta, sino también para la propia financiación del régimen vigente, y de su programa nuclear, a través del capital obtenido en los asaltos a sistemas informáticos internacionales.

Existe un beneficio generalizado del trabajo de los investigadores de amenazas cibernéticas, los

cuales, investigan las vulnerabilidades de los sistemas preexistentes para su corrección, analizan las amenazas emergentes, sus estrategias de ataque, y la forma de contrarrestarlas. En otras palabras, su trabajo hace de Internet un lugar más seguro.

En los próximos años el malware tradicional seguirá existiendo

- Se hará más popular el hacking en vivo Ataques sin malware
- Aprovechando las vulnerabilidades del sistema o utilizando ingeniería social.
- Los atacantes tomarán ventaja de las nuevas tecnologías realizando ataques sofisticados
- Usando Inteligencia Artificial y
- El aprendizaje automático...

El IoT o internet de las cosas actualmente contienen sistemas con baja seguridad conectados en hogares e industria y estos son la puerta de entrada de las redes domésticas y organizaciones

- No cifran la información ya que se obtiene mediante un forense del dispositivo
- Son difíciles de parchear.
- Si se compromete una red IoT puede utilizarse para realizar ataques de DDoS...

Existirán nuevas vulnerabilidades que afectarán a nivel mundial

- Problemas con la privacidad de datos.
- Además de los ataques habituales
- Fugas de información, ingeniería social, ransomware, suplantación de identidad...
- Destacando la figura del insider.
- Existe una alta demanda en las empresas de personal de ciberseguridad y formación.

Datos sobre seguridad de la información y ciberseguridad.

Hasta hace no mucho, la ciberseguridad era vista como un asunto técnico que se dejaba a los expertos de TI. Sin embargo, con la profunda dependencia tecnológica de muchas empresas, junto con los procesos de transformación digital que muchas organizaciones están acometiendo, el nivel de amenaza se ha incrementado exponencialmente, por lo que se requiere una estrategia holística para tratar el riesgo de ciberseguridad como otros riesgos a nivel organizativo (incluyendo el riesgo financiero, riesgo operacional, etc), siendo una parte fundamental del comité de dirección de las organizaciones.

El impacto de la ciberseguridad

De acuerdo al informe “2018 Cyber Incident & Breach Trends Report por la Online Trust Alliance“:

El impacto mundial de los ciberataques fue de al menos 38.000 millones de euros.

El 95% de las brechas de seguridad podrían haber sido evitadas.

5.000 millones de registros fueron expuestos.

De acuerdo al informe 2018” Cost of a Data Breach Study: Global Overview“ por el Instituto Ponemon e IBM:

El coste promedio de una fuga de datos es de 3,9 millones US \$. Aquellas empresas que tenían un equipo de gestión de incidentes maduro redujeron el coste medio en 1,2 millones de US \$.

El tiempo medio de detección y contención de una brecha es de 279 días (206 días la detección y 76 la contención) .

El grueso del coste de una brecha se concentra el primer año (67%), pero los costes siguen en el segundo (22%) y posteriores (11%)

Finalmente, de acuerdo al informe “Global Information Security Survey 2019” por EY:

Un 77% de las empresas sigue operando con un sistema de ciberseguridad y resiliencia limitado. No tienen una idea clara de cuáles son y dónde están tanto su información como sus activos más críticos, ni disponen de las garantías adecuadas para protegerlos.

Los 5 activos más importantes para las empresas por orden de importancia son los datos de los clientes, la información financiera, los planes estratégicos, la información de miembros del consejo y las contraseñas de los clientes.

El 30% de las empresas consultadas cita la escasez de perfiles cualificados en ciberseguridad y el 25% alude a restricciones presupuestarias. Las empresas de menor tamaño mantienen su preocupación en el hecho de que la función de seguridad de la información no satisface sus necesidades o debería mejorar.

Ejemplos de casos reales

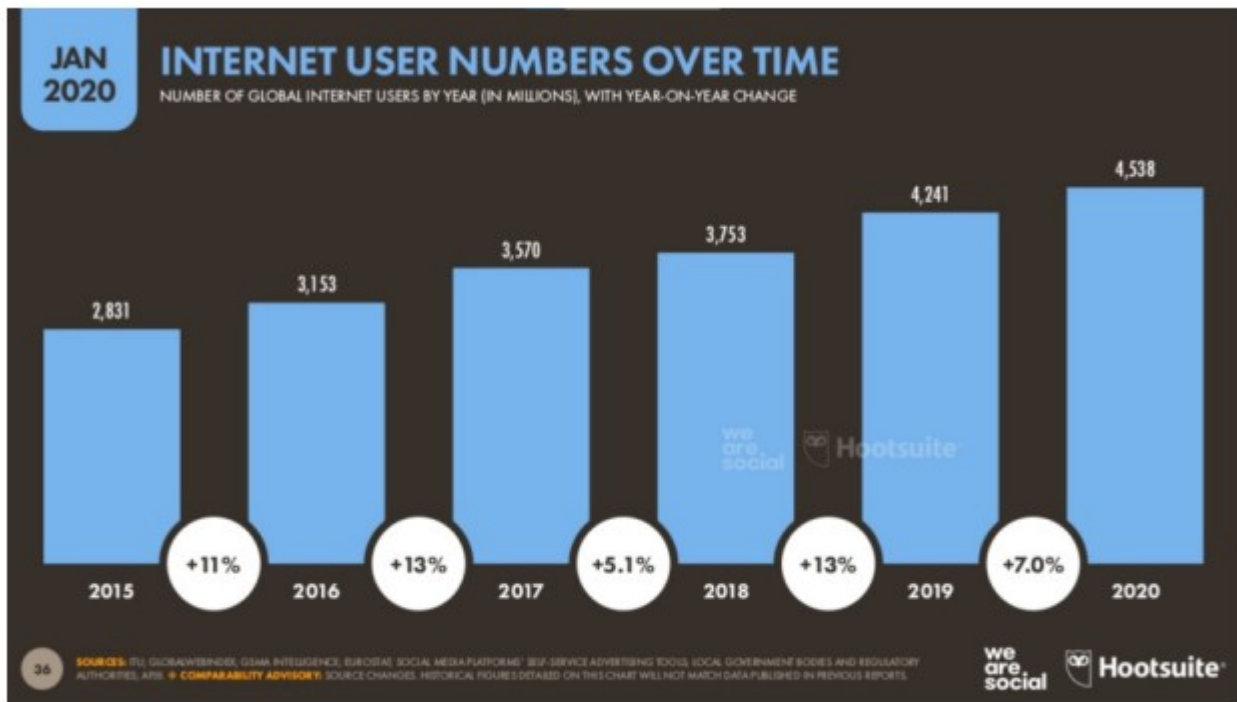
A continuación se muestran ejemplos de algunos incidentes famosos de los últimos años:

Maerk: En 2017, uno de los líderes mundiales de transporte de contenedores a nivel mundial, fue afectado por el ransomware NotPetya, con el resultado de que en menos de 10 minutos su red completa a nivel mundial quedó infectada y todos los equipos Windows cifrados. Durante dos semanas sus operaciones quedaron colapsadas mientras el equipo de TI reinstalaba desde cero 45.000 PCS y 4.000 servidores. El sistema del directorio activo estaba replicado en cada nodo, pero sin copias de seguridad. Gracias a que el nodo de una sucursal estaba caído por un mantenimiento salvaron una copia completa sin cifrar y no tuvieron que reconstruir la estructura completa (debiendo llevar la copia del nodo mediante avión dado que era tan pesada que tardaría días mandarla por internet debido a su ancho de banda). El coste entre horas extra, servicios externos, pérdida de clientes y compensaciones financieras fue de unos 300 millones de dólares.

Equifax: En septiembre de 2017, Equifax, empresa de información crediticia, anunció un incidente de seguridad de datos que expuso la información personal de 147 millones de personas. Bajo un acuerdo resolutorio presentado hoy, la compañía ha aceptado el pago de hasta \$425 millones de dólares en compensaciones. La información obtenida por los atacantes era la suficiente para crear identidades, tarjetas de crédito y préstamos falsos y posiblemente incluso robar directamente de tarjetas de crédito y cuentas bancarias. El incidente se produjo debido a una vulnerabilidad no parcheada en el servidor web. El daño reputacional se agravó dado que ocultaron el incidente durante semanas.

Marriot: A finales de 2018, Marriot, la mayor cadena hotelera mundial, descubrió una brecha de seguridad activa desde 2014. La exposición de información deriva de un ciberataque sufrido por un proveedor de servicios externo que trabajó anteriormente para Marriott. Así, un grupo de hackers logró comprometer las bases de datos de Starwood, una de las múltiples marcas de Marriott, exponiendo casi 390 millones de registros, incluyendo 8,6 millones de números de tarjetas de pago. Desde Inglaterra, la Oficina del Comisionado de Información impuso una sanción de 110 millones de euros por violación del reglamento de protección de datos. Así mismo debió pagar a los millones de usuarios afectados un año de un servicio de protección contra el robo de identidad en internet para paliar los posibles efectos de la filtración.

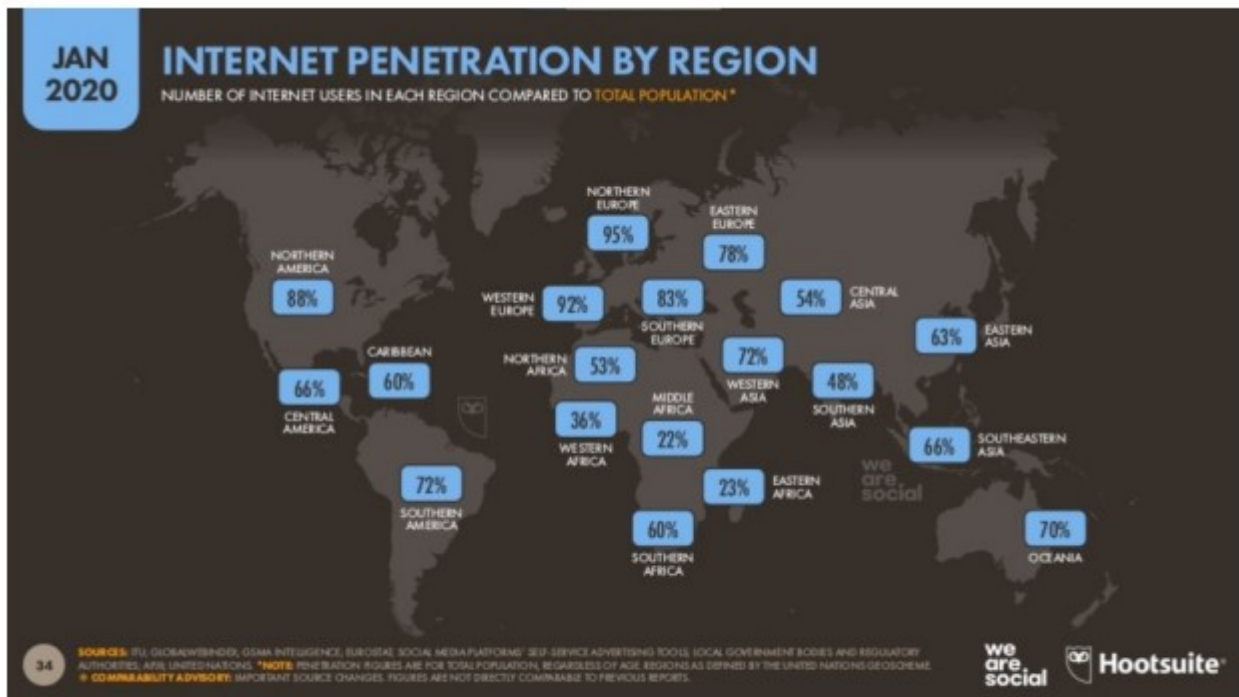
Facebook: En Marzo de 2019 se notificó que las contraseñas de cientos de millones (entre 200 y 600) de usuarios de Facebook habían sido recopiladas por aplicaciones creadas por ingenieros internos y recopiladas en claro (sin cifrar). Así mismo, de acuerdo a fuentes internas, unos 2000 ingenieros habrían realizado unas 9 millones de consultas sobre los conjuntos de datos que incluían las contraseñas en claro.



Número de usuarios de Internet en el mundo (2015-2020).

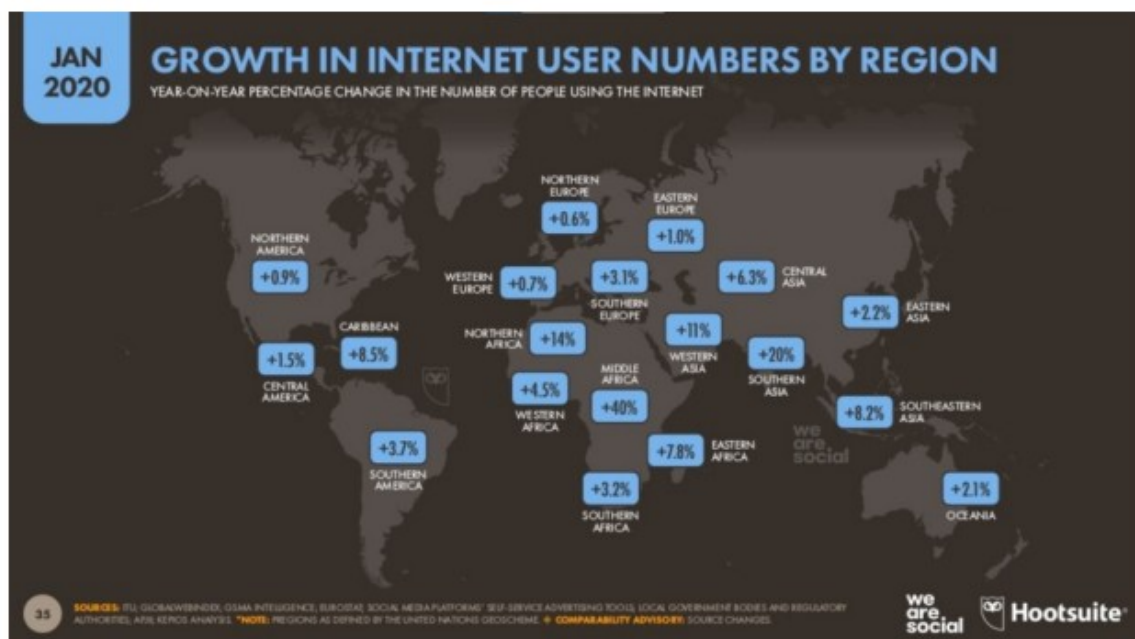
De acuerdo con los datos publicados en 2020 por la agencia “We Are Social” y la plataforma de gestión de redes sociales “Hootsuite”, en 2019, más de 4 mil millones de personas usaron Internet en todo el mundo, es decir, el casi el 60 por ciento de la población total del mundo está interconectada. Este número también sigue creciendo de manera continua, y se estima que más de 321 millones de nuevos usuarios se unirán a la Red en 2020.

Aun así, el grado de penetración de Internet es irregular. Mientras en los Emiratos Árabes Unidos el 99% de los habitantes están conectados a Internet, en Sudán no se llega a un 8%.



Grado de penetración de Internet en las diferentes regiones del mundo.

Los diferentes grados de asimilación de Internet en las vidas de los habitantes de las diferentes regiones del mundo, suelen estar vinculados a su grado de desarrollo. Esto es, incluso independientemente de la realidad política de la zona geográfica, se cumple que a mayor renta per cápita, mayor penetración de Internet entre su población. Sin embargo, en los últimos años, debido a la ubicuidad de Internet y a las ventajas intrínsecas de su utilización, el grado de penetración de esta tecnología está aumentando a un ritmo extremadamente mayor en las regiones depauperadas respecto a aquellas en las que el empleo de Internet se ha extendido a unos niveles casi totales de aceptación.



Aumento de número de usuarios de Internet (%) en las distintas regiones del mundo.

Dimensiones, áreas y ubicación de la ciberseguridad.

Las dimensiones de la seguridad

La seguridad se puede definir por varias dimensiones:

- **Confidencialidad:** es la propiedad de la información, por la que se garantiza que está accesible únicamente a personal autorizado a acceder a dicha información.
- **Integridad:** Es la propiedad de la información, por la que se garantiza la exactitud de los datos transportados o almacenados, asegurando que no se ha producido su alteración, pérdida o destrucción, ya sea de forma accidental o intencionada, por errores de software o hardware o por condiciones medioambientales.
- **Disponibilidad:** Se trata de la capacidad de un servicio, un sistema o una información, a ser accesible y utilizable por los usuarios o procesos autorizados cuando éstos lo requieran.
- **Trazabilidad:** Se trata del conjunto de procesos, técnicas y herramientas que permiten conocer el histórico, la ubicación y la trayectoria de un dato, conjunto de información o transacción a lo largo de la cadena de suministros en un momento dado. Es decir, saber dónde ha estado, quién ha accedido y/o modificado el dato, etc.
- **No repudio/Autenticidad:** El no repudio en el envío de información a través de las redes es capacidad de demostrar la identidad del emisor de esa información. El objetivo que se pretende es certificar que los datos, o la información, provienen realmente de la fuente que dice ser.

Otros conceptos de seguridad

Adicionalmente, existen otra serie de conceptos que es importante conocer:

- **Amenaza:** Circunstancia desfavorable que puede ocurrir y que tendría consecuencias negativas sobre los activos, provocando su indisponibilidad, funcionamiento incorrecto o pérdida de valor. Puede tener causas naturales, ser accidental o intencionada. Si esta circunstancia desfavorable acontece a la vez que existe una vulnerabilidad o debilidad de los sistemas o aprovechando su existencia, puede derivar en un incidente de seguridad.
- **Auditoría de seguridad:** Es el estudio que comprende el análisis y gestión de sistemas llevado a cabo por profesionales en TI con el objetivo de identificar, enumerar y describir las diversas vulnerabilidades que pudieran presentarse en una revisión exhaustiva de las estaciones de trabajo, redes de comunicaciones, servidores o aplicaciones.
- **Business Impact Analysis (BIA):** Se trata de un informe que nos muestra el coste ocasionado por la interrupción de los procesos críticos de negocio. Este informe nos permitirá asignar una criticidad a los procesos de negocio, definir los objetivos de recuperación y determinar un tiempo de recuperación a cada uno de ellos.
- **Defensa en profundidad:** El concepto de defensa en profundidad (o defensa en capas) se basa en la premisa de que todo componente de un sistema puede ser vulnerado, y por tanto no se debe delegar la seguridad de un sistema en un único método o componente de protección. De esta forma propone el uso de distintas técnicas que permitan, al menos, duplicar los elementos de protección para limitar los daños en caso de una intrusión en la primera línea de defensa o componente más expuesto.
- **Fuga de información:** La fuga de datos o fuga de información es la pérdida de la confidencialidad de la información privada de una persona o empresa. Información que, a priori, no debería ser conocida más que por un grupo de personas, en el ámbito de una organización, área o actividad, y que termina siendo visible o accesible para otros.
- **Incidente de seguridad:** Cualquier suceso que afecte a la confidencialidad, integridad o

disponibilidad de los activos de información de la empresa. Por ejemplo: acceso o intento de acceso a los sistemas, uso, divulgación, modificación o destrucción no autorizada de información.

- **SGSI:** Un Sistema de Gestión de Seguridad de la Información es para una organización el diseño, implantación, mantenimiento de un conjunto de procesos para asegurar la confidencialidad, integridad y disponibilidad de los activos de información, minimizando a la vez los riesgos de seguridad. Se trata de un proceso continuo que busca detectar posibles desviaciones así como cambios en los activos o en el entorno para adaptar y evolucionar dicho sistema.
- **Vulnerabilidad:** Fallos o deficiencias de un programa que pueden permitir que un usuario no legítimo acceda a la información o lleve a cabo operaciones no permitidas de manera remota. Los agujeros de seguridad pueden ser aprovechados por atacantes mediante exploits.

Áreas de actuación de la Ciberseguridad

- Desarrollar políticas de seguridad
- Identificar y eliminar vulnerabilidades Pentesting y auditorías de seguridad
- Controlar el acceso a la información y a los dispositivos
- Implementar mecanismos de protección
- Aplicar servicios de seguridad...

Ubicación de la Ciberseguridad

- Campos de la ciberseguridad - Actualmente la ciberseguridad debe de ser la suma de la seguridad de las redes y la seguridad de los sistemas de información. Esta suma es parte de la seguridad de la información o SEGURIDAD DE LA INFORMACIÓN.
- Ubicación de la ciberseguridad. La SEGURIDAD DE LA INFORMACIÓN incluye toda la seguridad de la información (en cualquier formato) de las personas, de los documentos, en las instalaciones, sistemas, en los datos de carácter personal y garantía de derechos fiscales. Toda esta información es la que puede ser objeto de ser atacada.
- Ciberseguridad y tecnología. Cuando la tecnología es imprescindible lo normal es dedicar los máximos esfuerzos posibles para que siempre funcione, sobre todo las empresas con dependencia tecnológica, que cada vez son más, deberían velar para que todos los elementos de la organización puedan hacer su trabajo. Por lo tanto deberían evitar incidentes y responder a los imprevistos accidentales o intencionados. Para las empresas no son opciones válidas perder la información sensible o parar la producción de la empresa, esto significaría en muchos casos parar la actividad, perder la reputación y la confianza de su entorno. Las acciones para prevenir los incidentes o los daños derivados de ellos hay que tenerlos claros para desarrollar las tareas necesarias orientados a cada uno de ellos:

- *Realizar las copias de seguridad*
- *Actualizar el software*
- *Controlar los accesos a los sistemas*
- *Gestionar las altas y bajas del usuarios*
- *Gestionar las contraseñas*

- *Gestionar los incidentes de seguridad*
- *Planificar la recuperación ante desastres...*

Las **acciones preventivas** pueden evitar en mayor medida que los incidentes ocurran y si llegan a ocurrir que no sean graves y puedan remediarse rápidamente, para ello una tarea importante será desarrollar planes de contingencia para asegurar la continuidad de negocio.

Premisas de la estrategia de ciberseguridad.

Independencia: Las empresas tienen que adoptar medidas de ciberseguridad según su entorno y operación, es decir particular y adecuada. Se deberán obtener medidas proactivas para prevenir incidentes o ataques lo que supone:

- Valorar los efectos de posibles incidentes tanto en la reputación y daños económicos.
- Incluir la ciberseguridad en la estrategia empresarial, es decir fomentar la cultura de seguridad.

Interdependencia:

- Sumando fuerzas la lucha contra los ciberdelincuentes es más efectiva.
- Genera beneficios
- Proteger los datos de los clientes y exigir a colaboradores, proveedores...
- Cumplir las leyes y normas de confianza a los clientes
- Crear una sinergia aliándose con otras empresas para responder a incidentes y hacer frente común a ciberdelincuentes.

Mejora continua:

Permite mejorar y optimizar de forma continua la seguridad ya que la tecnología avanza y el entorno cambia por lo tanto es necesario reconsiderar la seguridad lo que supone:

Actualizar las políticas de seguridad

- Formar periódicamente a los empleados
- Y revisar las estrategias con frecuencia.